VEL SOFTWARE SOLUTIONS · VEL-CSE-001
Companion template to the Custom Software & Enterprise Solutions Department Handbook · v1.0 · 4 November 2026

Appendix G — Code Review and Security Checklist

Pull-request review

- [ ] Linked to a story/defect; scope is small and focused.
- [ ] Tests added/updated and meaningful; CI green.
- [ ] No business logic in controllers/UI; layering respected.
- [ ] Validation at edge, domain and DB where relevant.
- [ ] Errors handled; no swallowed exceptions; safe messages to clients.
- [ ] Logging has correlation ID and **no secrets/PII**.
- [ ] Docs/ADR/OpenAPI updated.
- [ ] Migrations reviewed by Database Engineer.

Security (OWASP Top 10 aligned)

- [ ] Access control: server-side checks at endpoint and object level (A01).
- [ ] Cryptography: TLS everywhere; passwords hashed with a modern adaptive algorithm (Argon2id/bcrypt/PBKDF2); keys in a secret store (A02).
- [ ] Injection: parameterised queries; encoded output (A03).
- [ ] Insecure design: threat model and abuse cases exist (A04).
- [ ] Misconfiguration: debug off, headers set, default accounts removed, CORS allow-list (A05).
- [ ] Vulnerable components: dependency/SBOM scan and update plan (A06).
- [ ] AuthN failures: MFA option, lock-out, session expiry, no credential stuffing paths (A07).
- [ ] Integrity: signed builds/pinned actions; no unsafe deserialisation (A08).
- [ ] Logging & monitoring: security events logged and alerted (A09).
- [ ] SSRF: outbound allow-list for URL fetchers (A10).
- [ ] Secret scan passes; no secrets in repo history.
- [ ] File upload rules (Ch 7) applied.

Approval

Role	Name	Signature	Date
Reviewer			

Role	Name	Signature	Date
Technical Lead			